

PROJECT 3: PHISHING TRIAGE TOOLKIT

Cyber Security Internship – DecodeLabs

Submitted By: Jayesh Joshi

Internship: Cyber Security Internship

Organization: DecodeLabs

1. Objective

The goal of this project is to create a Phishing Triage Toolkit. The Phishing Triage Toolkit will help people figure out if something is a phishing attempt. It will also help them decide what kind of phishing attempt the Phishing Triage Toolkit is dealing with and what to do about the phishing attempt.

The Phishing Triage Toolkit is meant for people who're not tech experts. The Phishing Triage Toolkit will help these people spot messages that seem fishy and take the steps to keep their organizations important stuff and private information safe, from phishing attempts and the phishing attempts that the Phishing Triage Toolkit is designed to prevent.

2. Introduction

Phishing is a way that attackers try to trick you into doing something you should not do. They pretend to be someone you trust like a bank or a friend to get you to tell them things send them money or do something that you are not supposed to do.

These days phishing is not about fake emails. Now people are using QR codes, fake voices that sound real fake payment notices and even pretending to be important people at your company to trick you. They try to make you feel scared or like you have to do something away or they try to make you curious so you will do what they want.

To stay safe from these tricks' companies, need to have a plan, in place to help people figure out if something is real or not. This plan should help people look at messages they get and decide if they are okay if they look suspicious or if they are definitely bad. Companies need to have a system to deal with phishing so people can protect themselves from these people and the phishing attacks they use.

3. Human Firewall Framework

The most effective defense against phishing is the Human Firewall approach based on three simple principles:

Step 1: PAUSE

Before interacting with a suspicious message:

- Stop and think.
- Avoid clicking links immediately.
- Do not download attachments.
- Identify emotional triggers such as:
 - Urgency
 - Fear
 - Authority
 - Financial pressure

Example:

"Your account will be suspended within 24 hours."

Step 2: VERIFY

Verify the request through a secondary communication channel.

Verification Methods:

- Call the sender using an official contact number.
- Contact HR directly.
- Confirm requests with the finance department.
- Use the official company directory.

Never:

- Verify using the contact information provided in the suspicious message itself.

Step 3: REPORT

Report suspicious communications immediately.

Actions:

- Use the phishing reporting feature.
- Inform the IT Security Team.
- Escalate high-risk incidents.

Avoid:

- Simply deleting the message.

Reporting helps protect other users from the same threat.

4. Common Phishing Threat Categories

4.1 Business Email Compromise (BEC)

This is when attackers pretend to be people at a company or someone the company trusts. They do this to trick employees into sending them money or telling them secrets.

For example, someone might send an email that looks like it is from the CEO. The email will say something, like "we need to send money now before the day is over".

Here are some signs that this might be happening:

- * The person is asking for money fast
- * They are pretending to be someone
- * They are telling you to skip the steps we take to stay safe

Risk Level: High

4.2 Payment Failure Scam

Some people try to trick us by pretending to be companies we trust that we pay every month. They say that our payment did not go through.

For example:

They might send a message that says "Your subscription payment failed. You need to update your billing information now."

Things to watch out for:

- * They make us think we have to do something about our bill away
- * They put a link to pay in the message
- * They say they will stop our account if we do not pay

Risk Level: High

They are trying to get our money by making us think our payment, for the payment failure scam did not go through. The payment failure scam is a problem because people are trying to trick us with the payment failure scam.

4.3 Quishing (QR Phishing)

Attackers use malicious QR codes that redirect victims to fake login pages.

Example:

A fake Google Account Recovery notification asking users to scan a QR code.

Indicators:

- Unexpected QR code
- Login request after scanning
- Unknown destination

Risk Level: High

4.4 Deepfake Voice Phishing

Attackers use AI-generated voices to impersonate executives or trusted individuals.

Example:

A voicemail from a fake company director requesting immediate action.

Indicators:

- Unusual urgency
- Financial requests
- Request for secrecy

Risk Level: High

4.5 Callback Phishing (TOAD)

A fake notification instructs users to call a fraudulent support number.

Example:

Microsoft subscription renewal notice with a fake customer support number.

Indicators:

- Phone number instead of website
- Unexpected charges
- Pressure to call immediately

Risk Level: High

4.6 Password Reset Scam

Attackers send fake password expiration notices.

Example:

"Your password expires in 24 hours. Reset it now."

Indicators:

- Urgent password reset
- Login page links
- Credential requests

Risk Level: High

4.7 HR Policy Update Scam

Attackers impersonate Human Resources departments.

Example:

A fake healthcare benefits questionnaire requiring immediate completion.

Indicators:

- Unexpected HR requests
- Personal information collection
- Strict deadlines

Risk Level: Medium to High

4.8 Fake Meeting Invitations

Attackers send spoofed Teams or Google Meet invitations.

Example:

Meeting invitation containing a credential-harvesting link.

Indicators:

- Unknown organizer
- Unexpected meeting
- Login request

Risk Level: Medium to High

5. Email Header Analysis Checklist

Check	Purpose
Sender Address	Verify legitimacy of sender
Domain Name	Identify spoofed domains
Return-Path	Confirm sender authenticity
Reply-To Address	Detect redirection attempts
SPF Record	Verify authorized sender
DKIM Signature	Validate message integrity
DMARC Status	Detect spoofing attempts

Example-:

Legitimate -:

support@microsoft.com

Suspicious -:

support@m1crosoft-security.com

Reason:

The domain name has been manipulated to resemble a legitimate organization.

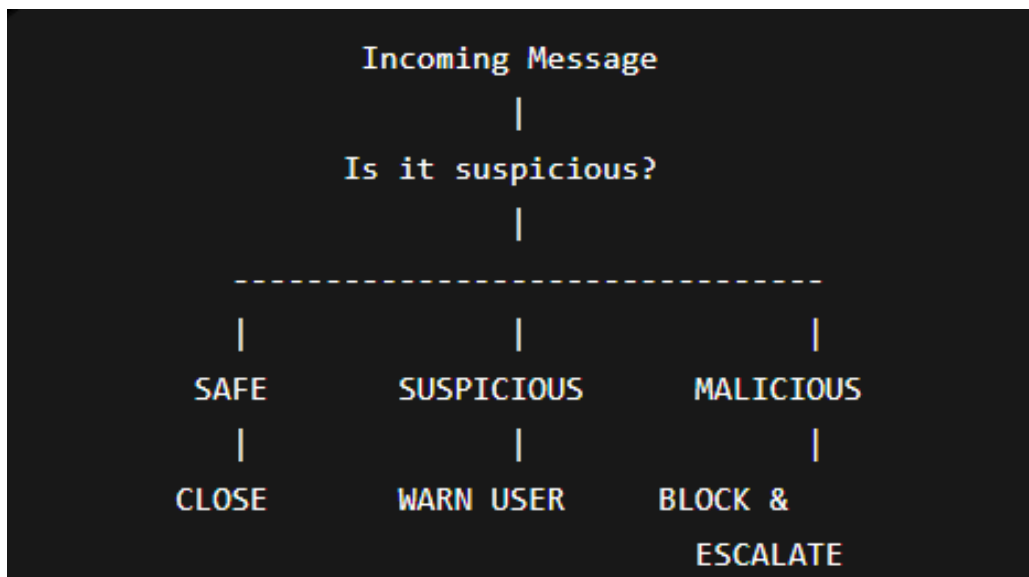
6. URL Inspection Checklist

Before clicking any link:

Verify:

- ✓ HTTPS enabled
- ✓ Correct domain spelling
- ✓ No random characters
- ✓ No unnecessary redirects
- ✓ URL matches official organization

7. Phishing Triage Decision Tree



8. Threat Classification Matrix

Indicator	Safe	Suspicious	Malicious
Verified Sender	✓		
Minor Anomalies		✓	
Unusual Urgency		✓	
Request for Credentials			✓
Wire Transfer Request			✓
Fake Login Page			✓
QR Code Redirect			✓
Deepfake Voice Request		✓	
Domain Spoofing			✓

9. Response Actions

Safe

Action:

- **Close the case.**
- **No further action required.**

Suspicious

Action:

- Warn the user.
- Verify sender identity.
- Monitor for additional activity.

Malicious

Action:

- Block sender or domain.
- Escalate to Security Operations Team.
- Remove message from all inboxes if possible.
- Document the incident.

10. Best Practices for Employees

1. Never click suspicious links.
2. Verify requests through secondary channels.
3. Avoid sharing credentials via email.
4. Report suspicious communications immediately.
5. Check sender addresses carefully.
6. Be cautious of urgent requests.
7. Never trust QR codes from unknown sources.
8. Verify payment-related notifications independently.

11. Conclusion

Phishing attacks continue to evolve through executive impersonation, payment scams, QR phishing, deepfake voice attacks, and spoofed internal communications. Organizations can significantly reduce risk by implementing a structured triage process based on the Pause–Verify–Report framework.

The Phishing Triage Toolkit developed in this project provides a practical approach for identifying threats, classifying suspicious communications, and taking appropriate actions to protect organizational resources and strengthen the Human Firewall.

